

Manual 54 — Gestão de Risco de Modelos de IA e Validação Independente

Fonte controlada de publicação — português do Brasil (pt-BR)

Data de verificação: 1 de setembro de 2026

Status de liberação: fonte candidata

Objetivo

Este manual estabelece um programa prático de gestão de risco de modelos e validação independente para IA preditiva, IA generativa, sistemas RAG e IA agêntica. Integra princípios de risco empresarial com métodos de teste, avaliação, verificação e validação (TEVV), preservando o escopo real e o status normativo de cada fonte.

Disciplina sobre o status das fontes

O NIST AI RMF 1.0 continua sendo orientação voluntária e está em revisão. O NIST AI 200-2 TEVV-Athlon é um Initial Public Draft em 2026 e deve ser tratado como orientação emergente de avaliação, não como padrão final obrigatório. O NIST AITE é um programa voluntário de avaliação. Para organizações bancárias dos Estados Unidos, a orientação supervisória de risco de modelos aplica-se ao seu âmbito setorial e não deve ser apresentada como obrigação universal para organizações não bancárias. A abordagem deve ser proporcional ao perfil de risco, porte, complexidade e materialidade.

Modelo operacional de validação

Caso de uso/materialidade → inventário → premissas/limitações → dados → metodologia/implementação → desempenho/robustez → segurança/equidade/explicabilidade → testes GenAI/RAG/agênticos → supervisão humana → desafio a terceiros → achados/disposição → monitoramento/revalidação.

MRM-01 — Classificação do caso de uso e materialidade

Validar finalidade de negócio, partes afetadas, consequência das decisões, autonomia, sensibilidade dos dados, impacto financeiro ou operacional, exposição regulatória e reversibilidade. Registrar materialidade, responsável, nível de aprovação e caminho de escalonamento.

MRM-02 — Inventário do modelo e do sistema

Validar modelo, fornecedor, versão, orquestração, prompts de sistema, repositórios de recuperação, ferramentas, agentes, fluxos de dados, hospedagem e dependências. Inventariar o sistema de IA completo, e não apenas o modelo matemático ou fundacional.

MRM-03 — Premissas e limitações

Identificar premissas explícitas e implícitas, faixas operacionais suportadas, incerteza, modos de falha conhecidos, usos proibidos, condições de borda e dependência de alegações de terceiros. O validador independente deve desafiar premissas materiais e não apenas repetir a documentação do desenvolvimento.

MRM-04 — Validação de dados

Avaliar proveniência, linhagem, representatividade, qualidade, vazamento, duplicação, contaminação, integridade de rótulos, relevância temporal, tratamento de dados sensíveis e separação treino/teste quando aplicável. Documentar condições de dados que possam invalidar conclusões de desempenho.

MRM-05 — Metodologia e implementação

Avaliar se a metodologia escolhida é adequada ao uso pretendido e se a implementação em produção corresponde ao desenho aprovado. Utilizar reprodutibilidade, revisão de código/configuração, cálculos independentes ou métodos alternativos conforme a materialidade.

MRM-06 — Desempenho e robustez

Testar desempenho com métricas apropriadas ao objetivo, incerteza, cenários de estresse, mudança de distribuição, casos extremos, estabilidade, calibração quando relevante e limites explícitos de falha. Evitar dependência de uma única métrica agregada quando ela puder ocultar falhas importantes por subgrupo ou cenário.

MRM-07 — Segurança e resiliência adversarial

Desafiar prompt injection, envenenamento, exfiltração, execução insegura de saídas, abuso de ferramentas, escalada de privilégios, integridade da cadeia de suprimentos, mudanças de fornecedor, exaustão de recursos e capacidade de contenção. Vincular achados à evidência de segurança do Manual 52.

MRM-08 — Equidade e viés prejudicial

Quando relevante ao caso de uso e aos requisitos aplicáveis, avaliar desempenho por subgrupos, indicadores de impacto desigual, efeitos de proxy, desequilíbrio de dados e eficácia das mitigações. Documentar quando uma métrica de equidade não se aplica e por quê; não afirmar que uma única métrica prova ausência de viés prejudicial.

MRM-09 — Explicabilidade e rastreabilidade de decisões

Validar se explicações, atribuição de evidências, proveniência, registros de decisão e justificativas voltadas a pessoas são adequados ao caso de uso. Não representar técnicas de explicação como se revelassem uma verdade interna além de sua capacidade real.

MRM-10 — Factualidade, fundamentação e risco de alucinação em GenAI

Definir testes específicos de factualidade e fundamentação, expectativas de fontes de referência, verificações de citações/proveniência, limites de alegações não sustentadas, comportamento de abstenção, tratamento de incerteza e regras de escalonamento. Avaliar fluxos reais e não apenas benchmarks isolados.

MRM-11 — Qualidade e autorização de recuperação RAG

Validar elegibilidade de fontes, relevância, atualidade, autorização, isolamento entre locatários, fragmentação/indexação, resistência a envenenamento, fidelidade de citações e prevenção de recuperação não autorizada. Medir tanto a qualidade da resposta quanto a integridade da evidência recuperada.

MRM-12 — Risco de ação agêntica

Validar identidade do agente, autoridade delegada, permissões de ferramentas, limites de ação, limiares de aprovação humana, delegação entre agentes, limites de transação/recursos, reversão, contenção e logs atribuíveis. Testar salvaguardas sob instruções adversariais ou ambíguas.

MRM-13 — Efetividade da supervisão humana

Testar se revisores designados conseguem compreender, intervir, rejeitar, substituir, interromper, escalar e documentar decisões antes de consequências materiais. Uma pessoa nominal no fluxo não é suficiente se o desenho técnico ou processual impedir intervenção significativa.

MRM-14 — Validação de dependências de terceiros

Desafiar alegações de fornecedores, model cards, declarações de segurança, avisos de mudança, compromissos contratuais, continuidade do serviço, controles de versão, opções de saída e disponibilidade de evidências. Registrar quais alegações foram reproduzidas independentemente e quais permanecem dependentes de declarações do fornecedor.

MRM-15 — Monitoramento e revalidação

Definir métricas, limites de drift, incidentes, mudanças de fornecedor/modelo/dados/ferramentas, falhas de controle, degradação de desempenho e gatilhos temporais de revalidação. O escopo da revalidação deve refletir a materialidade da mudança.

MRM-16 — Achados, aprovação condicional e disposição

Classificar achados por severidade e materialidade. Rastrear remediação, controles compensatórios, risco residual aceito, aprovação condicional, restrições de uso, datas de expiração e evidência de encerramento. Achados graves não resolvidos exigem disposição explícita de responsável com autoridade; a equipe de validação deve poder registrar dissenso.

Critérios de independência

A validação independente deve ser organizacional e intelectualmente separada do desenvolvimento primário em grau proporcional à materialidade. Os validadores devem poder desafiar premissas, reproduzir ou testar alegações de forma independente, registrar discordâncias, escalar achados não resolvidos e evitar validar suas próprias decisões de desenho sem controles compensatórios.

Pacote obrigatório de cenários

1. Mudança de distribuição que deteriora o desempenho.
2. Mudança silenciosa de versão em modelo hospedado por terceiro.
3. Alucinação de GenAI em fluxo de trabalho consequencial.
4. RAG recupera conteúdo desatualizado ou não autorizado.
5. Agente tenta atuar fora de limite aprovado.
6. Supervisão humana existe no papel, mas é ineficaz na prática.
7. Contaminação da avaliação por dados usados em treino ou ajuste.

8. Alegação de terceiro não pode ser reproduzida independentemente.
9. Solicitação de aprovação condicional com achado de segurança aberto.
10. Drift material ainda abaixo de um limite numérico rígido.

Catálogo de evidências

- EV-01 Carta e escopo de validação.
- EV-02 Avaliação de caso de uso/materialidade.
- EV-03 Inventário do modelo/sistema.
- EV-04 Diagramas de arquitetura e fluxo de dados.
- EV-05 Registro de premissas/limitações.
- EV-06 Testes de qualidade e proveniência de dados.
- EV-07 Resultados reproduzíveis de desempenho.
- EV-08 Testes de robustez/estresse.
- EV-09 Resultados de testes adversariais e de segurança.
- EV-10 Avaliação de equidade quando aplicável.
- EV-11 Avaliação de factualidade/fundamentação GenAI.
- EV-12 Avaliação de recuperação/autorização RAG.
- EV-13 Testes de limites de ação agêntica.
- EV-14 Teste de efetividade da supervisão humana.
- EV-15 Desafio de evidência de terceiros.
- EV-16 Registro de achados e remediação.
- EV-17 Registro de aprovação condicional ou risco residual.
- EV-18 Plano de monitoramento e revalidação.

Regra de liberação

Validação não é um selo único de aprovação. A evidência deve demonstrar desafio independente, testes reproduzíveis ou de outra forma sustentáveis, achados claros, disposição responsável e gatilhos definidos de revalidação. Orientação emergente deve permanecer identificada como rascunho e orientação supervisória setorial deve preservar seu escopo real.